

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

DEVELOPING SECURITY POLICIES AND PROCEDURES

WEEK 3 PRACTICAL LABORATORY

NAME	ESTHER EGBAGBE
REGISTRATION NUMBER	C11/26/CGRCE/17574
COHORT	COHORT 11
COURSE	GRC102
DATE SUBMITTED	25 rd of Sept.2026

Evidence Bundle 1: Governance gap assessment, stakeholder map, organization chart and justification

1. Governance Gap Assessment

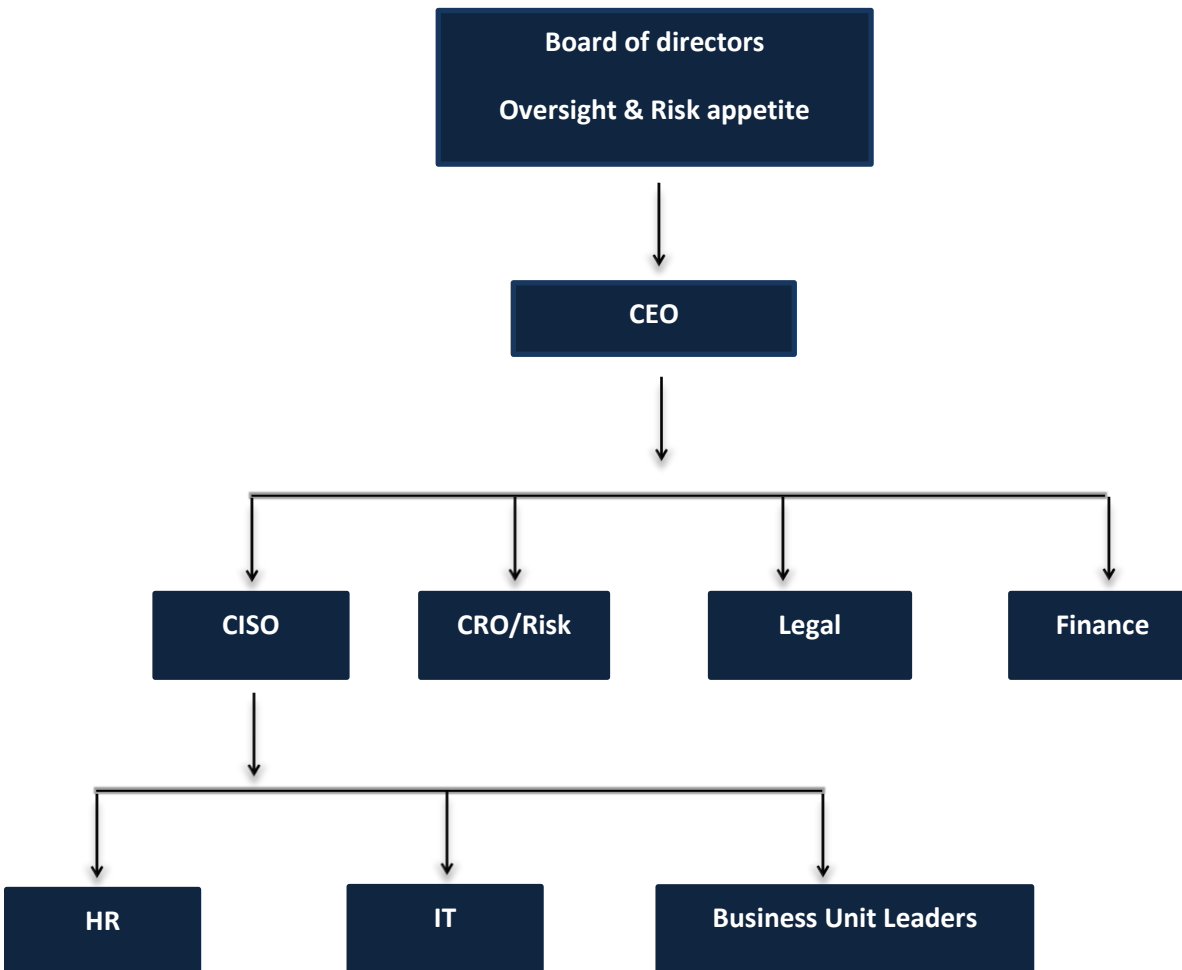
- a) **The IT Director is currently making, approving, and carrying out security decisions:** This is a segregation of duties problem because there is no independent person checking those decisions. It can also make IT focus more on what is technically convenient instead of what is best for the business. The proposed structure fixes this by giving different responsibilities to different people: the CISO handles security strategy and policies, the CRO/Board handles risk acceptance, and Internal Audit provides independent checks.
- b) **There is no formal governance committee:** Important risk and investment decisions are made by one person without input from other departments like Legal, Finance, or HR. The proposed structure fixes this by creating two committees: the Executive Security Council for major strategic decisions and the Security Governance/Steering Committee for operational decisions. This makes sure important decisions are not made by just one person.
- c) **Business units apply security inconsistently across the five offices:** This can create security gaps and increase the risk of attacks. The proposed structure includes Business Unit Leaders and Security Champions in the Steering Committee to make sure all five offices follow the same security policies and standards.
- d) **The Board and CEO do not have enough information about the company's cyber risks:** Without regular updates, they may not know about important security issues or risks facing the business. The proposed structure creates a clear reporting line from the CISO to the Executive Security Council, CEO, and Board Risk Committee, so everyone stays informed about cyber risks.
- e) **There is no clear process for escalating serious security incidents:** This means an important incident may not reach the executives or Board on time, which could also lead to missing

regulatory deadlines. The proposed structure creates a clear reporting path, but only when an incident meets the defined conditions for escalation.

2. Stakeholder Map

Stakeholder	Primary Interest	Authority/Influence	Information Needed	Governance Contribution
Board	Regulatory exposure, reputation, and responsibility	Ultimate oversight, sets risk appetite	Quarterly risk report, material incident briefs, audit results	Approves strategy/appetite, receives escalations
CEO	Growth vs. risk balance	Resource allocation, cross-functional arbitration	CISO briefings, business impact analysis	Endorses strategy to Board, sets tone from the top
CISO	Programme effectiveness, risk oversight	Owens security strategy and policy	Threat intel, incident data, control metrics	Runs the programme, reports up, chairs Steering Committee
CRO/Risk	Risk aggregation across all domains	Enterprise risk methodology, risk acceptance	Cyber risk register, KRIs	Integrates cyber risk into enterprise risk register
Legal/Compliance	Regulatory duty, privacy, contracts	Regulatory interpretation, notification decisions	Incident details, jurisdiction affected	Advises on notification obligations, reviews policy
Finance	Loss exposure, ROI on controls	Budget approval	Budget requests, incidents cost data	Funds the programme, tracks financial impact
HR	Insider risk, awareness, conduct	People-policy enforcement	Access violations tied to staff, training completion	Manages joiner/mover/leaver access, discipline
IT/Technology	Service continuity	Technical implementation	Approved architecture standards	Implements controls
Business Unit Leaders	Performance, local risk	Local operational decisions	Applicable policy, unit risk register	Implement locally, escalate risks, nominate champions

3. Security Governance Organization Chart



4. Consultant Justification

TechGlobal's current security structure gives the IT Director too much control because the same person makes, approves, and carries out security decisions. There is also no formal governance committee, the five offices do not always follow security practices in the same way, the Board has limited visibility into cyber risks, there is no clear process for escalating serious incidents, and there is no independent team checking if security controls are actually working.

The proposed structure fixes these problems by sharing responsibilities between different people and teams. The CISO and Executive Security Council will handle security strategy and major decisions, while IT, Security Management, and the business units will handle implementation

This structure works better for TechGlobal because the company has five offices. Having one person make every decision does not allow enough input from the different offices, while allowing each office to make its own decisions could lead to inconsistent security practices. The proposed Steering Committee allows the offices to contribute while still following one central security framework. If TechGlobal opens a sixth office, it can easily be added to the same structure.

Each problem has a specific solution. The CISO, CRO/Board, and Internal Audit have separate responsibilities for security, risk acceptance, and independent checks. The Executive Security Council and Steering Committee make sure important decisions are not made by one person. The CISO also reports through the Council to the CEO and Board, keeping leadership informed about cyber risks and serious incidents.

Finally, Internal Audit remains independent and reports directly to the Board Audit Committee. This prevents the same conflict that existed in the current structure.

Overall, the new structure gives TechGlobal clear responsibility, accountability, and independent oversight.

Evidence Bundle 2: Governance responsibility matrix, role profiles and conflict-resolution note

1. Cross-functional Governance Responsibility Matrix

Role	Purpose	Core Responsibility	Decision Authority	Reports/ Escalates To	KPIs/Evidence
Board	Ultimate oversight of enterprise Risk, including cyber	a) Set risk appetite b) Approve strategy at a high level c) Demand assurance that controls work	a) Approves risk appetite statement b) Ratifies major strategic direction	Shareholders/ regulators	Briefings delivered on time
CEO	Translate Board risk appetite into executive accountability	a) Endorse security strategy to the Board b) Arbitrate cross-functional conflicts c) Own overall business risk posture	a) Approves budget recommendations before Board sign-off	Board	Escalation resolution time
CISO	Own and lead the security	a) Set security strategy and policy	a) Approves security policy	CEO/CRO	Policy review % Critical vulnerability MTTR

	governance programme	b) Run risk oversight c) Chair the steering committee d) Report programme effectiveness upward	and architecture standards b) Recommends budget/risk acceptance		
CRO/Risk	Integrate cyber risk into enterprise-wide risk management	a) Own risk methodology b) Aggregate cyber risk into enterprise risk register c) Formally accept/reject risk within delegated authority	a) Final sign-off on risk acceptance within threshold b) Escalates above-threshold risk to the Board	CEO/Board	Risk treatment coverage
Legal	Ensure regulatory and contractual obligations are met	a) Advise on regulatory duties b) Own the final call on breach notification c) Review policy for legal exposure	a) Final decision authority on whether/when a regulatory notification is made	CEO/Board	Deadline compliance %
Finance	Govern financial resourcing and control of the security programme	a) Approve/allocate security budget b) Track loss exposure and incident cost	a) Approves final budget allocation	CEO/Board	Budget variance Cost tracking accuracy
HR	Govern people-related risk controls	a) Manage the employees b) Run security awareness training c) Handle policy-violation discipline	a) Owns disciplinary outcomes for policy violations b) Sets awareness training requirements	CEO/Board	Training completion %
IT	Implement and operate the technical controls the CISO's policies require	a) Build and maintain infrastructure controls b) Execute approved architecture standards c) maintain service continuity	a) Implement-level technical decisions within CISO approved standards	CEO/Board	Baseline compliance %

2. Role Profiles/ Responsibility cards for the eight core governance roles

Board — Purpose: hold ultimate oversight of enterprise risk, including cyber, on behalf of shareholders and regulators. Set risk appetite, approve strategy at a high level, demand assurance controls work. Approves risk appetite and accepts/rejects material risk. Reports to shareholders/regulators.

CEO — Purpose: translate Board risk appetite into executive accountability. Endorse strategy to the Board, arbitrate cross-functional conflicts, own overall business risk posture. Approves budget recommendations, resolves cross-departmental disputes. Reports to the Board.

CISO — Purpose: own and lead the security governance programme. Set strategy and policy, run risk oversight, chair the Steering Committee. Approves security policy and architecture standards, recommends budget and risk acceptance. Reports to CEO/CRO.

CRO/Risk — Purpose: integrate cyber risk into enterprise-wide risk management. Own risk methodology, aggregate cyber risk into the enterprise register, formally accept/reject risk within delegated authority. Final sign-off on risk acceptance within threshold escalates above it. Reports to CEO/Board.

Legal — Purpose: ensure regulatory and contractual obligations are met. Advise on regulatory duties, own the final call on breach notification, review policy for legal exposure. Final authority on notification decisions. Reports to CEO/Board.

Finance — Purpose: govern financial resourcing of the security programme. Approve/allocate budget, track loss exposure and incident cost. Approves final budget allocation. Reports to CEO/Board.

HR — Purpose: govern people-related risk controls. Manage employees, run awareness training, handle policy-violation discipline. Owns disciplinary outcomes and training requirements. Reports to CISO/Steering Committee.

IT — Purpose: implement and operate the technical controls the CISO's policies require. Build/maintain infrastructure controls, execute approved standards, and maintain continuity. Implementation-level decisions within CISO-approved standards. Reports to CISO/Security Management.

3. Conflict-resolution note identifying overlapping authority and resolution principles

1. CISO vs. CRO on risk acceptance. Both touch cyber risk decisions — CISO assesses and recommends, CRO formally accepts/rejects within threshold.

Resolution: CISO is Responsible, CRO is Accountable; anything above CRO's threshold escalates to the Board.

2. CISO vs. IT on architecture/control ownership. IT builds infrastructure and could drift into setting its own standards, recreating a segregation-of-duties problem.

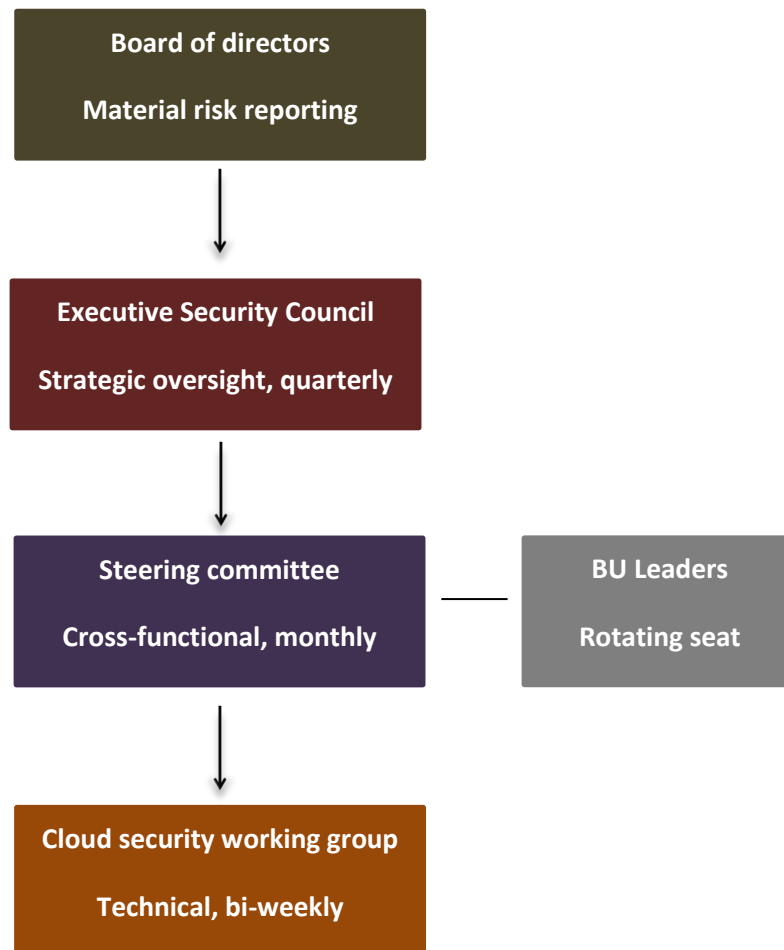
Resolution: CISO is Accountable for approving architecture standards; IT is Responsible for implementing within them, not setting them.

3. CISO vs. Legal on regulatory notification. CISO holds the incident data, but notification is a legal judgment with statutory consequences.

Resolution: Legal holds final Accountable authority on notification; CISO is consulted and supplies technical facts.

Evidence Bundle 3: Committee ecosystem, Terms of Reference, agenda, decision log and governance calendar

1. Committee structure / interaction diagram



2. Terms of Reference for the Security Governance Committee

Field	Detail
Purpose	Cross-functional forum to review and resolve security governance decisions spanning IT, Legal, HR, Finance, and business units
Scope	Policy exceptions, cross-functional risk items, working group escalations, BU security concerns
Chair	CISO
Membership	IT, Legal, Finance, HR representatives One rotating Business Unit Leader seat Cloud Security Working Group leader
Decision authority	Approves policy exceptions and cross-functional remediation plans within delegated threshold. Escalates anything above threshold to the Executive Security Council
Meeting Frequency	Monthly, Plus ad hoc sessions for urgent escalations
Quorum	CISO plus at least four other standing members
Reporting line	Reports into the Executive Security Council
Review cycle	ToR reviewed annually

3. Sample Committee Agenda (monthly Steering Committee meeting)

1. Call to order and check if there is a quorum
2. Review and approve the previous meeting minutes
3. Review previous decisions and their progress
4. Cloud Security Working Group update
5. Business unit risk updates
6. Review the cross-functional risk register
7. Review policy exception requests
8. Discuss issues that need to be escalated to the Executive Security Council
9. Any other business
10. Agree on the next meeting date

4. Sample decision Log

ID	Date	Issues	Decision	Owner	Status
DL-001	2026-10-06	Cloud Security Working Group requested exception to MFA Policy for a legacy vendor integration	Exception approved for 90 days, contingent on compensating network segmentation control	IT Lead	Open-review 2027-01-06
DL-002	2026-11-03	Inconsistent access review practice reported across three offices	Standardized quarterly access review process approved, effective next cycle	HR+IT	Closed
DL-003	2026-11-03	Elevated risk score on a critical third-party vendor flagged by working group	Escalated to Executive Security Council for risk acceptance decision	CISO	Escalated

5. 12-Month Governance Calendar

Month	Activity
January	Steering Committee(monthly)
February	Steering Committee, Executive Security Council (Q1)
March	Steering Committee, annual security policy review begins
April	Steering Committee
May	Steering Committee, Executive Security Council (Q2), Board risk briefing
June	Steering Committee , annual security awareness campaign
August	Steering Committee, Executive Security Council (Q3)
September	Steering Committee, internal audit of governance controls
October	Steering Committee, annual ToR review for all committee
November	Steering Committee, Executive Security Council (Q4), Board risk briefing
December	Steering Committee, annual governance programme review, following-year calender approved

Evidence Bundle 4: RACI matrix and implementation guide

1. Governance Responsibility Matrix (RACI)

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	A	C	R	C	I	C	I	I	I
Security policy approval	I	I	A	C	C	I	C	R	I
Enterprise cyber-risk assessment	I	I	R	A	C	C	C	C	C
Risk acceptance	I	C	R	A	C	C	I	I	C
Security budget approval	I	C	R	I	A	C	I	C	I
Security architecture approval	I	I	A	C	I	I	I	R	I
Third-party security review	I	I	A	C	C	C	I	R	C

Access governance	I	I	A	I	C	I	C	R	C
Incidence response governance	I	I	A	C	C	I	C	R	I
Material Incident escalation	I	A	R	C	C	I	I	R	I
Regulatory notification decision	I	I	C	C	A	I	I	I	I
Security awareness programme	I	I	C	I	I	I	A	I	C
Vulnerability remediation oversight	I	I	A	I	I	I	I	R	I
Business continuity / recovery governance	I	C	C	A	C	C	C	R	C
Board cyber-risk reporting	I	C	A	C	I	I	I	I	I

2. Three Problematic Assignments

a) Material incident escalation.

The CEO is marked Accountable here, but CISO and IT are the ones with actual eyes on the incident when it happens. That's a problem. In the first few minutes of a real incident, the CEO isn't in a position to own that decision competently; they don't have the technical picture yet. What should really happen is accountability moves as the incident moves: CISO owns the call on whether this even meets the threshold to escalate, and only once it's actually been escalated does the CEO become accountable for what happens next. The matrix as written doesn't show that handoff. It just picks one owner for the whole thing, which isn't how it actually works in practice.

b) Business continuity and recovery governance.

CRO is Accountable, and literally everyone else IT, CEO, CISO, Legal, Finance, HR is Consulted. Six people consulted and one person accountable is usually a sign the activity is too big to be one row. Think about what actually happens during a real outage: CRO owns "the risk," but CRO isn't the person making live recovery calls at 2am, IT is. So IT ends up making decisions they don't formally have authority for, while CRO holds the accountability on paper.

c) Risk acceptance.

CRO is Accountable, Board is just informed. That's fine as long as we're talking about risk within whatever threshold CRO's been delegated. But nothing in the matrix shows that this flips once you cross that threshold read cold, it looks like CRO can accept any risk, no ceiling, which obviously isn't the intent. And this isn't something you can fix by changing the RACI itself, since RACI only ever gives you one accountable party per row

3. Implementation Guide

Purpose: Why this exists. So that when someone's mid-planning, mid-approval, or mid-incident, they can look at this and know in ten seconds who actually owns the call instead of guessing or escalating blindly because nobody's sure whose decision it is.

Planning: Before anything on this list gets scheduled a policy review, a budget round, an architecture change find the Accountable person first and get their sign-off before calling it "planned." Responsible

people execute once that's locked. Consulted people need to weigh in before the sign-off happens, not after their input is supposed to shape the decision, not just get logged for the record. Informed people just get told the outcome; nobody owes them a conversation.

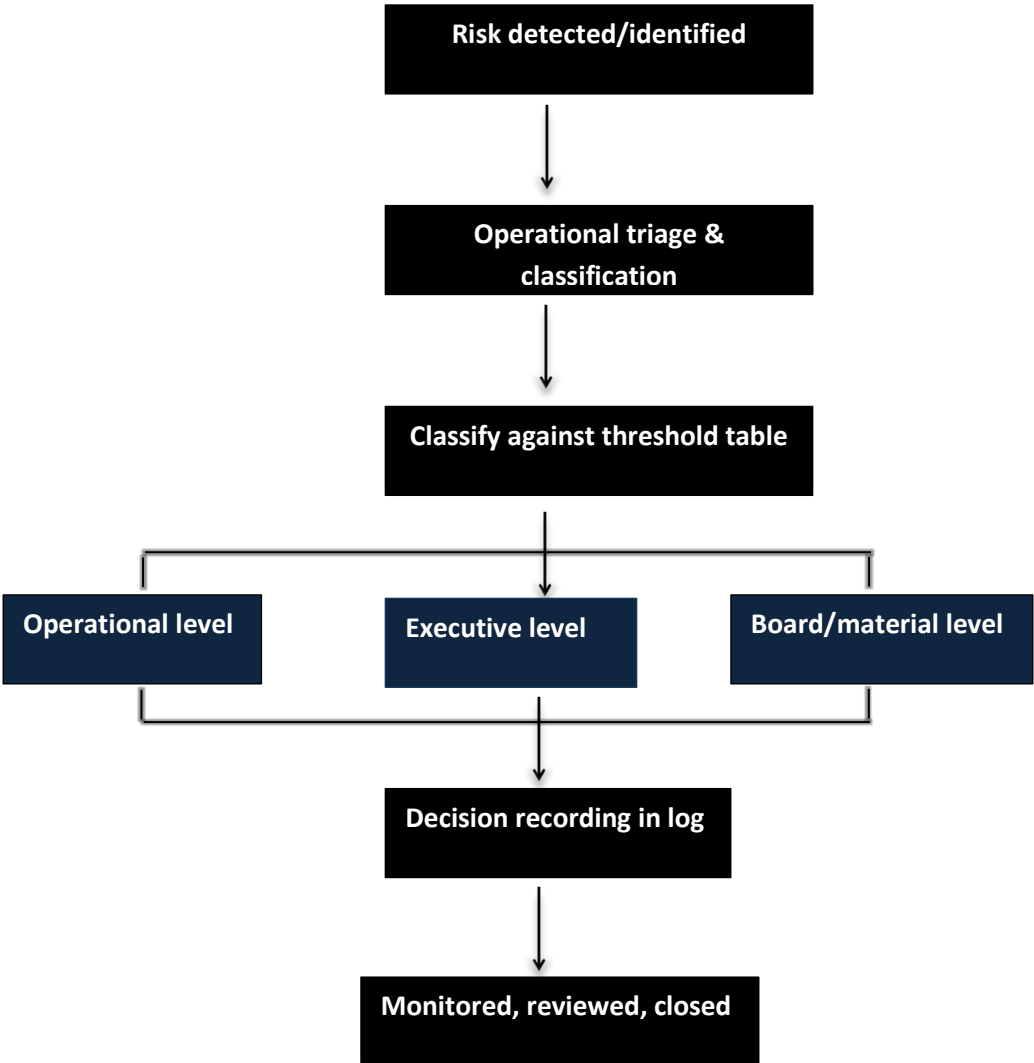
Approvals: An approval doesn't count unless the Accountable person's sign-off is actually recorded somewhere a verbal isn't enough for anything beyond routine stuff. If a row involves a Consulted party, put it in the decision log. And if two people both think they own the same decision, that's not something to quietly split down the middle that goes to the Steering Committee to sort out.

Incidents: This only works if people already know their row before something goes wrong not scrambling to look it up mid-incident. And incidents often hit more than one row at once. Say something's both an incident-response issue and a notification issue those run in parallel, each with its own owner. IT and CISO don't sit around waiting on Legal's notification call before they start containing the problem, and Legal doesn't wait on containment before figuring out if this needs to be reported.

Known limitation: As the problematic-assignment analysis above shows, a handful of these activities have accountability that should logically shift under certain conditions (severity, risk threshold). Managers should treat the "A" in this matrix as the default owner, not an unconditional one, and escalate to the Steering Committee if a specific situation seems to sit outside the assumption the row was built on.

Evidence Bundle 5: Cyber-risk escalation workflow and threshold table

Cyber-risk Escalation workflow



Escalation threshold

Level	Example Trigger	Decision Authority	Required Notification	Target Response Time
Level 1- Operational	Limited to a single, non-critical system; no regulated or customer data exposure; resolvable using standard operating	Security Analyst/IT Security Lead	Logged internally; CISO informed in routine summary	Contained/resolved within standard SLA(e.g., same business day)

	procedures			
Level 2 – Executive	Affects multiple systems, more than one business unit, or has possible regulatory relevance; cannot be resolved through standard procedures alone	CISO – Executive Security Council	CISO notifies CEO, Legal, Finance, HR as relevant; logged in decision register	Initial response same day; resolution tracked to close within an agreed short window
Level 3 – Material/Board	Confirmed exposure of regulated or customer data; significant operational disruption across the business; likely regulatory, legal, or reputational consequences	CEO/CISO – Board Risk Committee	Board notified immediately; Legal assesses statutory notification obligation	Immediate initial response; Board briefed without delay

Evidence Bundle 6: Segregation-of-Duties / Accountability Weakness Register and assurance note

Segregation-of-duties Weakness Register

ID	Weakness/Conflict	Risk Created	Roles involved	Recommended Control	Residual Risk/Review
1	IT Director owns, approves, and executes security decisions with no independent check	Decision optimized for technical convenience, not business risk	IT Director	Split ownership: CISO owns strategy, CRO owns risk acceptance, independent function provides assurance	Low, if roles are genuinely separated. Review annually at ToR review
2	No one independently verifies IT's self-reported control effectiveness	False confidence, controls assumed effective without evidence	IT, CISO	Quarterly self-assessment attestation reviewed by CRO	Moderate, still relies on IT's own reporting. Revisit needed for independence audit as company grows
3	Same person can raise a risk and decide to accept it	Risk minimized or waved through to	IT/Security Analyst	Require sign off from someone	Low if enforced. Review for compliance at each Steering committee

		avoid remediation cost/effort		outside the identifying team (CISO/CRO) for Level 2/3 acceptance	meeting
4	IT provisions and revokes its own privileged access with no HR trigger checks	Access can persist after role change or termination; insider risk	IT, HR	The privilege access changes to HR-confirmed employees events, logged and reviewable	Low, if automated. Review access logs quarterly
5	No documented record of who decided to accept, defer, or escalate a risk	No auditable trail; decisions cannot be defended after the fact	CISO, CRO, Board	Log every Level 2/3 decision in the decision register with rationale and review date	Low. Review log completeness at each steering committee/ council meeting

Decision-Recording and Assurance

Every Level 2 and Level 3 decision is recorded with the decision ID, date, issue, decision level, decision made, person who made the decision, reason for the decision, and review date.

Level 1 decisions are recorded as a summary instead of individually because they are routine and logging every single one could make the record unnecessarily long.

Level 2 decisions are reviewed at the next Steering Committee meeting to identify any patterns or recurring issues. Level 3 decisions are reviewed at the next Board Risk Committee meeting and remain open until the agreed remediation has been verified, not just completed.

This gives TechGlobal a clear record of its decisions. If someone asks months later, “Who accepted this risk and why?” there will be a documented answer instead of relying on people to remember.

References

REFERENCES

1. Institute of Internal Auditors. (2020). The IIA's three lines model: An update of the three lines of defense.
2. ISACA. (2018). COBIT 2019 framework: Governance and management objectives. ISACA.
3. ICDFA CGRCE Material. Roles and responsibilities in security governance